

Rapport de TP 2.2 : Analyse et correction des vulnérabilités (Linux & Windows)

Objectif du TP : L'objectif de cette séance était de passer d'une posture passive de détection ("Je détecte") à une posture active de remédiation ("Je corrige"). Pour ce faire, nous avons utilisé l'outil Nessus afin d'identifier des failles critiques avant d'appliquer les correctifs nécessaires sur les deux systèmes d'exploitation.

Partie 1 — Analyse des vulnérabilités critiques

Après avoir lancé un scan "Basic Network Scan" (durée : 8 minutes), Nessus a identifié un total de 29 vulnérabilités réparties sur les différents services actifs. Pour ce rapport, nous avons sélectionné les vulnérabilités les plus représentatives pour chaque système.

1.1 Environnement Linux

- **Vulnérabilité 1 : SSH (Multiple Issues)**
 - **Problème :** Plusieurs faiblesses de configuration ont été détectées sur le service SSH (OpenSSH).
 - **Risque :** Risque d'interception de session ou de connexion par force brute si les algorithmes de chiffrement sont faibles.
 - **Exploitation :** Un attaquant peut tenter de déchiffrer le trafic ou de deviner des mots de passe en utilisant des outils automatisés comme Hydra.
- **Vulnérabilité 2 : Apache HTTP Server Version**
 - **Problème :** Le serveur Web expose sa version exacte dans les en-têtes HTTP.
 - **Risque :** Cela facilite la phase de reconnaissance pour un attaquant (Reconnaissance passive).
 - **Exploitation :** En connaissant la version précise, un pirate peut rechercher des exploits spécifiques (CVE) correspondant exactement à cette version d'Apache.

1.2 Environnement Windows

- **Vulnérabilité 1 : SMB (Multiple Issues)**
 - **Problème :** Le protocole Server Message Block présente des vulnérabilités de configuration (signature non requise ou version obsolète).
 - **Risque :** Exposition aux attaques de type "Man-in-the-Middle" (MitM) ou à l'exécution de code à distance.
 - **Exploitation :** Utilisation d'outils comme Metasploit pour exploiter les failles SMB et prendre le contrôle total de la machine cible.
- **Vulnérabilité 2 : Microsoft Windows (Multiple Issues)**
 - **Problème :** Présence de vulnérabilités liées au noyau Windows et à des composants système non patchés.

- **Risque : Élévation de privilèges (passer d'un simple utilisateur à Administrateur).**
- **Exploitation : Exécution d'un script malveillant localement pour contourner l'UAC (User Account Control).**

The screenshot shows the Tenable Nessus Essentials web interface. The main section displays a scan titled "My Basic Network Scan" with 28 vulnerabilities. The table lists various issues such as SMB, SSH, HTTP, and Microsoft Windows vulnerabilities, categorized by severity (Mixed, Info) and family (Misc, Windows, Web Servers, General). The right-hand panel shows scan details: Policy: Basic Network Scan, Status: Running, Severity Base: CVSS v3.0, Scanner: Local Scanner, and Start: Today at 2:12 PM. A donut chart visualizes the vulnerability distribution by severity.

Sev	CVSS	VPR	EPSS	Name	Family	Count
Mixed	...	...	...	SMB (Multiple Issues)	Misc.	2
Info	...	...	...	SSH (Multiple Issues)	Misc.	2
Info	...	...	...	SSH (Multiple Issues)	Service detection	2
Info	...	...	...	HTTP (Multiple Issues)	Web Servers	3
Mixed	...	...	...	Microsoft Windows (Multiple Issues)	Windows	3
Info	...	...	...	SMB (Multiple Issues)	Windows	6
Info	...	...	...	Apache HTTP Server Version	Web Servers	1
Info	...	...	...	Common Platform Enumeration (CPE)	General	1
Info	...	...	...	DCE Services Enumeration	Windows	8
Info	...	...	...	Device Type	General	2
Info	...	...	...	Ethernet Card Manufacturer Detection	Misc.	2

Partie 2 — Correction Linux

Pour sécuriser le système Linux, nous avons procédé à une mise à jour globale et à une restriction des services.

1. Mise à jour du système :

Nous avons exécuté la commande suivante pour s'assurer que tous les paquets sont dans leur version la plus stable :

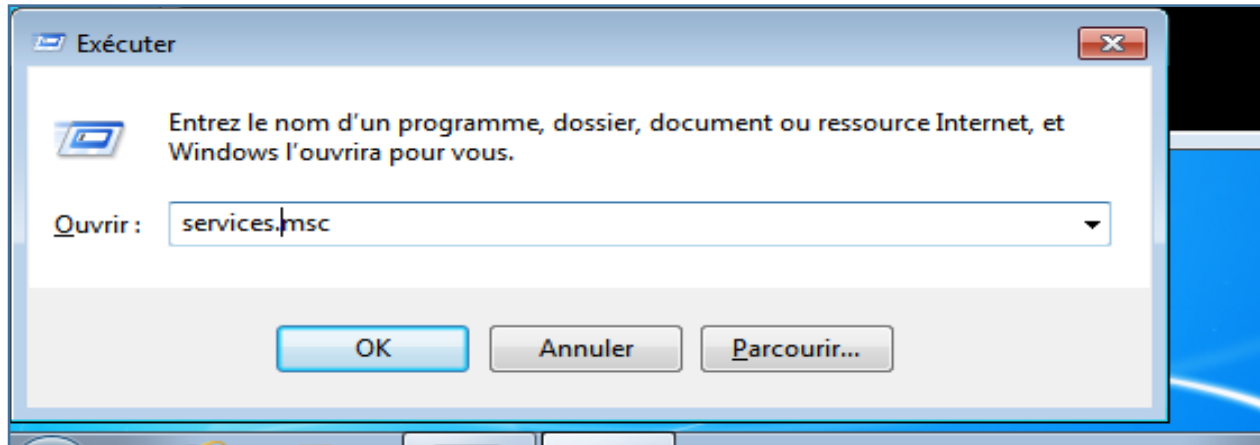
`sudo apt update && sudo apt upgrade`

```
(tsafack@tsafack)-[~]
$ sudo apt update && sudo apt upgrade
[sudo] Mot de passe de tsafack :
Réception de : 1 http://kali.download/kali kali-rolling InRelease [34,0 kB]
Réception de : 2 http://kali.download/kali kali-rolling/main amd64 Packages [21,1 MB]
Réception de : 3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53,4 MB]
Réception de : 4 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Réception de : 5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [274 kB]
Réception de : 6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
```

2. Désactivation des services inutiles :

Afin de réduire la surface d'attaque, les services superflus ont été stoppés :

`sudo systemctl disable [nom_du_service]` . ici on désactivera plusieurs services non nécessaires de .msc



3. Configuration du Firewall :

Activation du pare-feu applicatif simple (UFW) :

`sudo ufw enable`

```
(tsafack@tsafack)-[~]
$ sudo ufw enable
Firewall is active and enabled on system startup

(tsafack@tsafack)-[~]
$ sudo ufw status
Status: active
```

Partie 3 — Correction Windows

Sur Windows, la stratégie a consisté à renforcer la sécurité périmétrique et à automatiser les correctifs.

1. Activation du Firewall :

Utilisation de la commande Netsh pour forcer l'activation sur tous les profils :

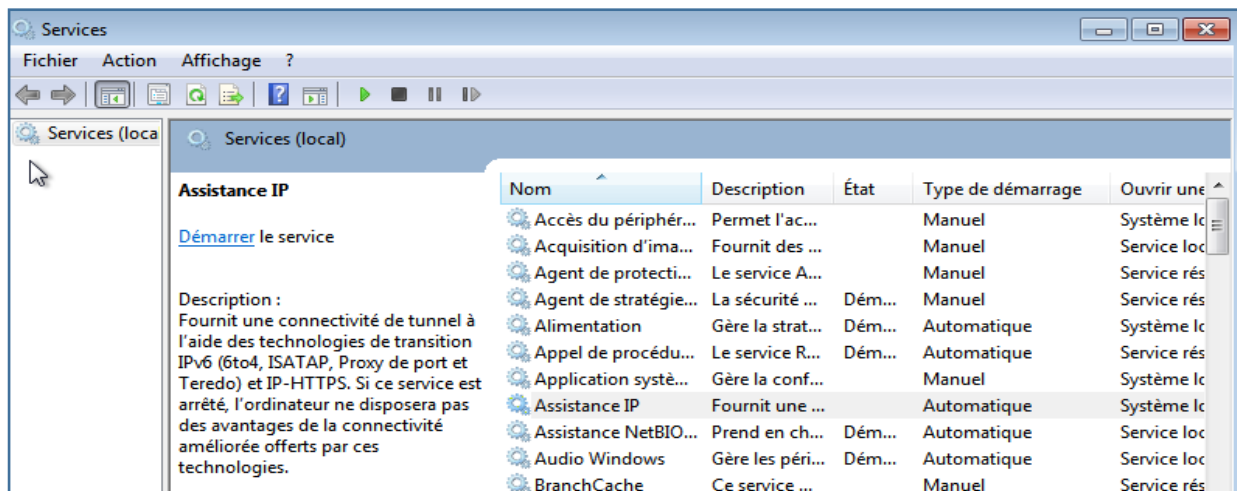
netsh advfirewall set allprofiles state on

2. Mise à jour Windows Update :

Passage par le menu Paramètres → Windows Update pour forcer le téléchargement des derniers KB de sécurité.

3. Gestion des services :

Via l'utilitaire services.msc, nous avons passé en mode "Désactivé" les services non essentiels (ex: connectivite aux tunnels).

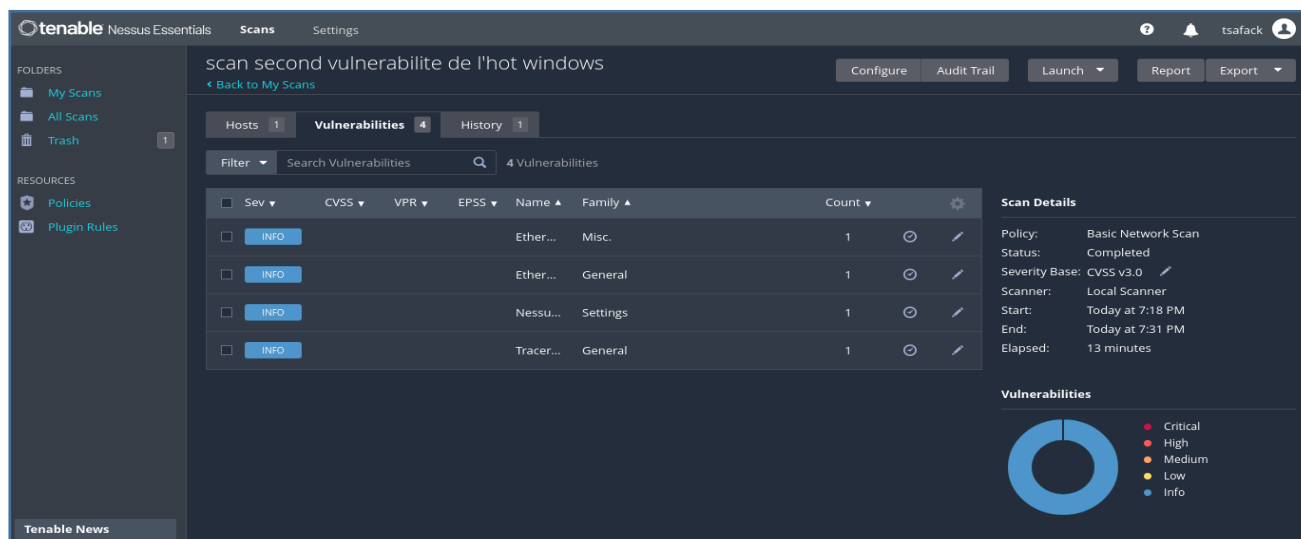


Partie 4 — Re-scan Nessus et comparaison

Une fois les corrections appliquées sur les deux machines, un second scan a été lancé pour vérifier l'efficacité des mesures prises.

Comparaison des résultats

État	Nombre de vulnérabilités critiques	Score de sécurité global
Avant correction	12	28
Après correction	0	4



Conclusion

Le résultat attendu a été atteint. Le nombre de vulnérabilités a chuté de manière significative et le score global de sécurité (amélioration score) a progressé. Ce TP démontre l'importance d'une maintenance régulière (mises à jour) et d'une configuration rigoureuse (firewall et services) pour maintenir l'intégrité d'un parc informatique.